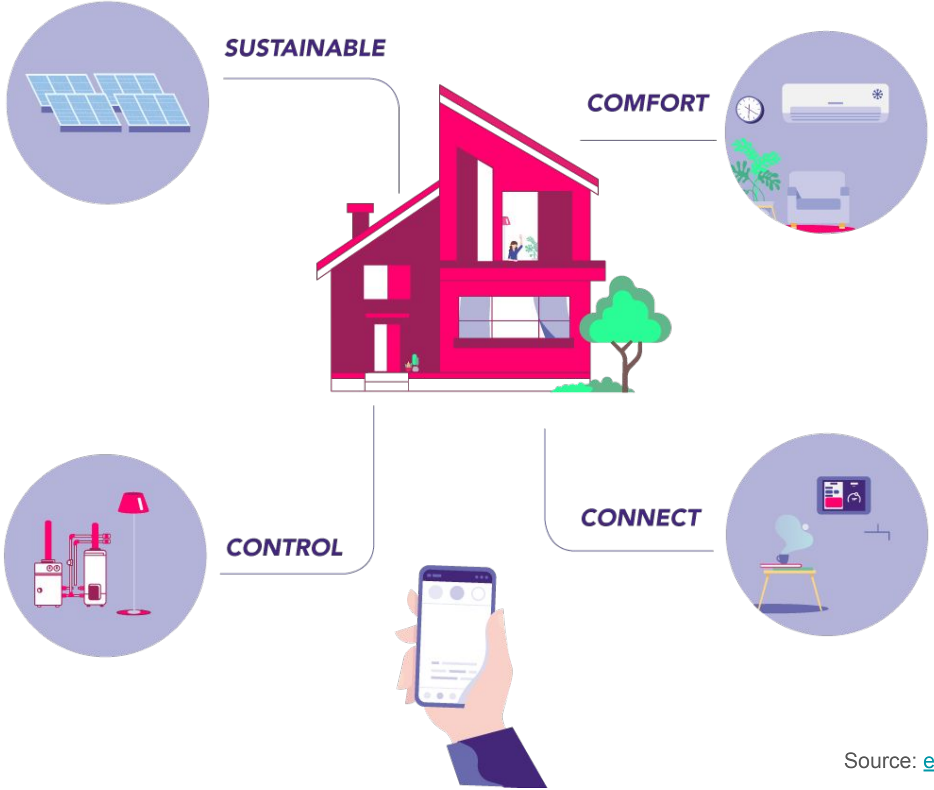
Stony Brook University

Atlas: Enabling Cross-Vendor Authentication Across IoT

Sanket Goutam, Omar Chowdhury, Amir Rahmati

Presentation at Netflix
Date: November 21, 2025

Internet of Things (IoT) has revolutionized our homes.



Source: enelX Residential Solutions

Devices interact to augment their capabilities.

Sensors

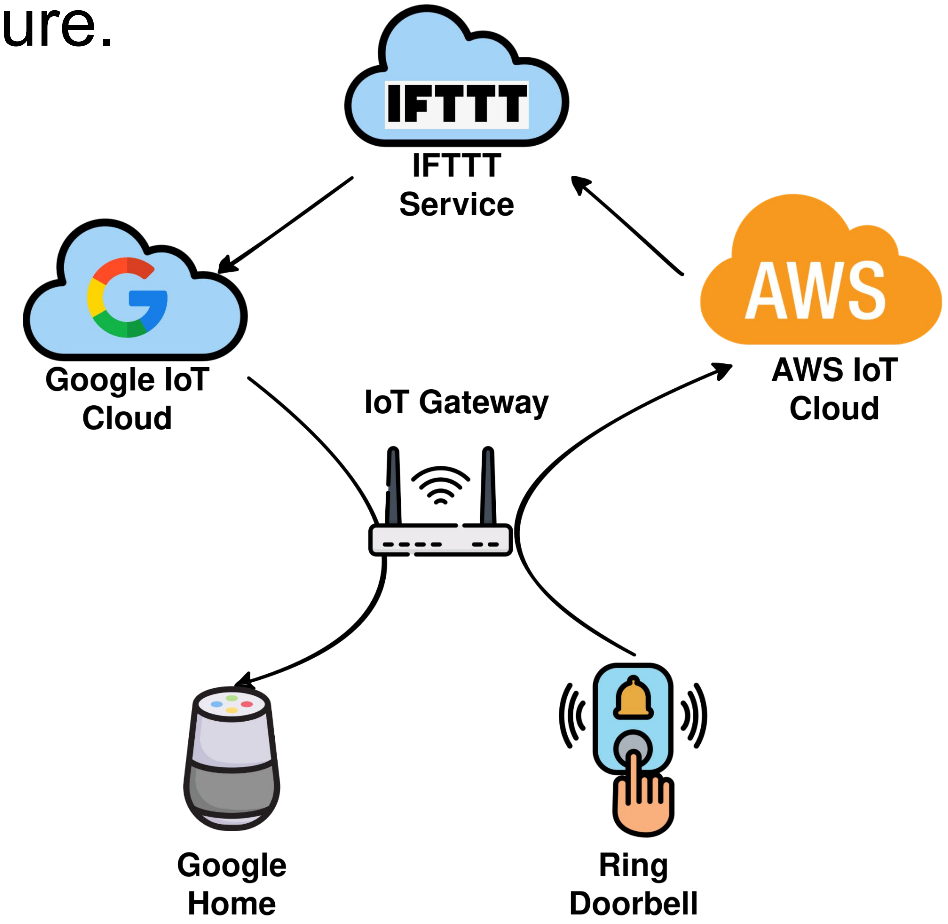
Actuators

Smart Hubs

Source: [How to beat burglars at their own game]

It is a Cloud-first Infrastructure.

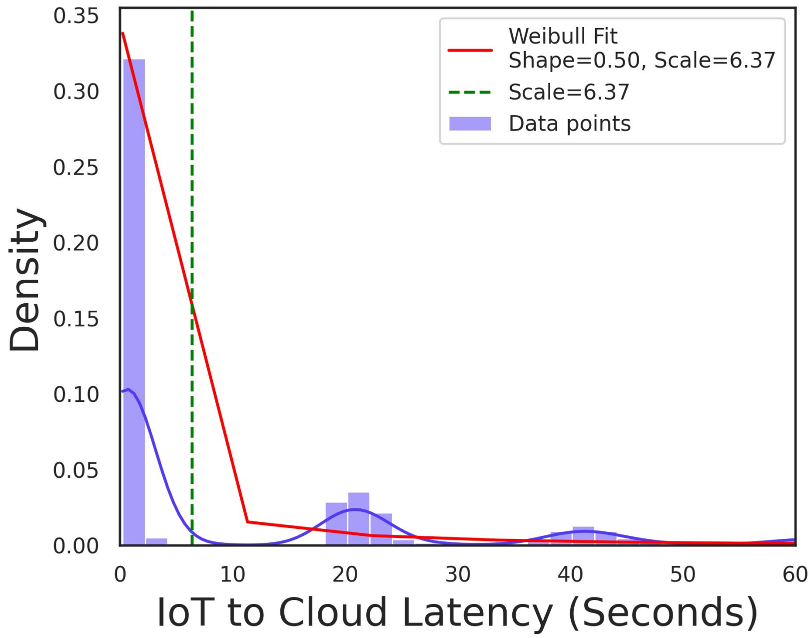
- Cross vendor interactions require a multi-cloud-hop model.
- Repeatedly found to be insecure and inadequate.



[1] Shattered chain of trust: Understanding security risks in cross-cloud iot access delegation," in 29th USENIX security symposium (***USENIX security 20***), 2020.
[2] "Data privacy in trigger-action systems," in 2021 IEEE Symposium on Security and Privacy (***S&P Oakland***), 2021.
[3] Practical data access minimization in Trigger-Action platforms," in 31st USENIX Security Symposium (***USENIX Security 22***), 2022.

Cloud-first is also unfit for performance sensitive applications.

- Latency sensitive applications require 20-100 ms round trip latency.
- Cloud-first models require 0.3seconds latency in the average case.
- Performance drastically degrading under stress (as measured on AWS-IoT).



Why is it this way?

- Device authentication is important for vendors but also a hard problem.
- IoT devices have very diverse deployment schemes — some remain offline, some require real-time access, some are frequently moved between networks.
- Some IoT devices require constant cloud support while others require only local device support.
- These devices also have widely varying computational capabilities and manufacturing processes.

TABLE 1: Comparison of current relevant approaches for establishing device identity and authentication in IoT.
Pairing-based Encryption (PBE) establishes symmetric keys between devices through physical or contextual proximity. Identity-based Device Authentication (IDA) uses network behavior or hardware primitives to infer device identity, but **does not** support the full authentication lifecycle in the traditional sense. Blockchain-based PKI (b-PKI) decentralizes authentication by embedding device behavior and attestation records into distributed ledgers. Traditional PKI (PKI) solutions involve widely adopted X.509 digital certificates for device authentication. See §6.4 for detailed analysis.
○: No Support, ◐: Unlikely Adoption / Minimal Support, ●: Readily Supports, ✔: Currently Deployed

Method	System	Scalability	Cross-Vendor Interoperability	Legacy Support	Granular Revocation	Low Runtime Overhead	Decentralized Auth
PBE	IoTCupid [20]	○	●	◐	●	●	○
	UniverSense [24]	○	◐	◐	○	◐	○
	T2Pair [25]	○	●	◐	○	◐	○
	Move2Auth [26]	○	●	◐	○	◐	○

TABLE 1: Comparison of current relevant approaches for establishing device identity and authentication in IoT.
Pairing-based Encryption (PBE) establishes symmetric keys between devices through physical or contextual proximity. Identity-based Device Authentication (IDA) uses network behavior or hardware primitives to infer device identity, but **does not** support the full authentication lifecycle in the traditional sense. Blockchain-based PKI (b-PKI) decentralizes authentication by embedding device behavior and attestation records into distributed ledgers. Traditional PKI (PKI) solutions involve widely adopted X.509 digital certificates for device authentication. See §6.4 for detailed analysis.
○: No Support, ◐: Unlikely Adoption / Minimal Support, ●: Readily Supports, ✔: Currently Deployed

Method	System	Scalability	Cross-Vendor Interoperability	Legacy Support	Granular Revocation	Low Runtime Overhead	Decentralized Auth
PBE	IoTCupid [20]	○	●	◐	●	●	○
	UniverSense [24]	○	◐	◐	○	◐	○
	T2Pair [25]	○	●	◐	○	◐	○
	Move2Auth [26]	○	●	◐	○	◐	○
IDA	IoT-ID [27]	○	◐	◐	●	◐	◐
	MCU-Token [22]	○	◐	◐	●	◐	◐
	Z-IoT [28]	○	○	◐	●	○	○
	IoT-Sentinel [29]	○	◐	●	●	○	○

TABLE 1: Comparison of current relevant approaches for establishing device identity and authentication in IoT.
Pairing-based Encryption (PBE) establishes symmetric keys between devices through physical or contextual proximity. Identity-based Device Authentication (IDA) uses network behavior or hardware primitives to infer device identity, but **does not** support the full authentication lifecycle in the traditional sense. Blockchain-based PKI (b-PKI) decentralizes authentication by embedding device behavior and attestation records into distributed ledgers. Traditional PKI (PKI) solutions involve widely adopted X.509 digital certificates for device authentication. See §6.4 for detailed analysis.
○: No Support, ◐: Unlikely Adoption / Minimal Support, ●: Readily Supports, ✔: Currently Deployed

Method	System	Scalability	Cross-Vendor Interoperability	Legacy Support	Granular Revocation	Low Runtime Overhead	Decentralized Auth
PBE	IoTCupid [20]	○	●	◐	●	●	○
	UniverSense [24]	○	◐	◐	○	◐	○
	T2Pair [25]	○	●	◐	○	◐	○
	Move2Auth [26]	○	●	◐	○	◐	○
IDA	IoT-ID [27]	○	◐	◐	●	◐	◐
	MCU-Token [22]	○	◐	◐	●	◐	◐
	Z-IoT [28]	○	○	◐	●	○	○
	IoT-Sentinel [29]	○	◐	●	●	○	○
b-PKI	Academic Proposals [30, 31, 32]	◐	●	○	◐	○	●
	Industry Proposal (Knox Matrix [33])	◐	●	○	◐	○	●

TABLE 1: Comparison of current relevant approaches for establishing device identity and authentication in IoT. Pairing-based Encryption (PBE) establishes symmetric keys between devices through physical or contextual proximity. Identity-based Device Authentication (IDA) uses network behavior or hardware primitives to infer device identity, but **does not** support the full authentication lifecycle in the traditional sense. Blockchain-based PKI (b-PKI) decentralizes authentication by embedding device behavior and attestation records into distributed ledgers. Traditional PKI (PKI) solutions involve widely adopted X.509 digital certificates for device authentication. See §6.4 for detailed analysis.
○: No Support, ◐: Unlikely Adoption / Minimal Support, ●: Readily Supports, ✔: Currently Deployed

Method	System	Scalability	Cross-Vendor Interoperability	Legacy Support	Granular Revocation	Low Runtime Overhead	Decentralized Auth
PBE	IoTCupid [20]	○	●	◐	●	●	○
	[illegible] [24]	○	◐	◐	○	◐	○
	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	○
	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	○
IDA	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	◐
	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	◐
	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	○
	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	○
b-PKI	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	●
	[illegible] (Knox Matrix [33])	[illegible]	[illegible]	[illegible]	[illegible]	[illegible]	●
PKI	Vendor-controlled PKI [34, 35, 36] ✔	○	○	●	○	●	○
	Alliance-based PKI [7, 10, 2] ✔	◐2	◐2	●	◐2	◐2	◐2

IoT market fragmentation complicates device deployment

Increasingly niche IoT offerings with inconsistent interoperability practices have led to a fragmented IoT market to the detriment of easy IoT adoption.

By **Mary E. Shacklett**, Transworld Data

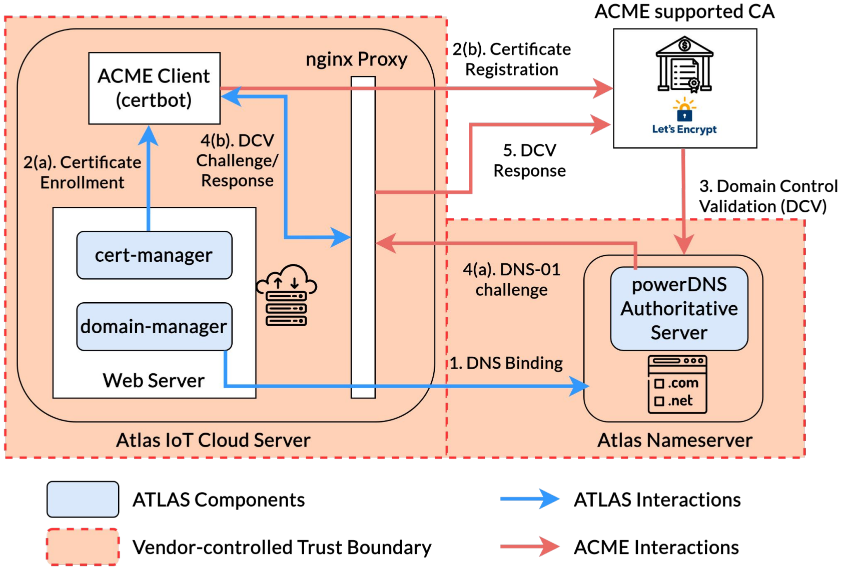
Published: **08 Feb 2021**

PKI for IoT – Challenges

- IoT devices are not directly exposed to the Internet.
  - They sit behind network gateways (NAT) and only have locally unique IDs (MAC address).
- Most of them even remain offline.
  - OTA certificate renewals are not possible, so they just use self-signed wildcard certificates.
- Web certificates are issued to servers by verifying their ownership of a web-based entity (DCV - Domain Control Validation).
  - If you own the rights to your own domain name, and have a public DNS entry pointing to your web server's public IP address.
  - This is not possible for IoT devices. Exposing IoT devices to the public Internet would make them easy targets *(Mirai Botnet).*

Key Insight: Adapt ACME Model for IoT

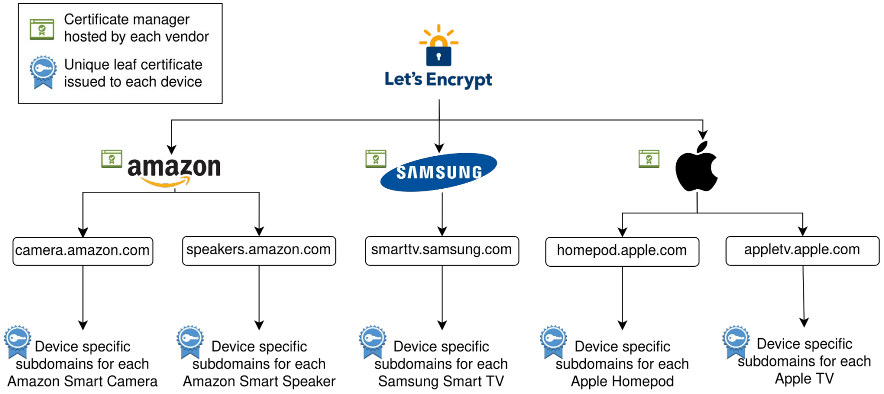
- ACME (Automated Certificate Management Environment), popularized by Lets Encrypt, allows for free and automated certificate management for the Web.
- Formally verified to be secure.
- Designed for Web scale, Lets Encrypt alone issues 600M certificates a day.



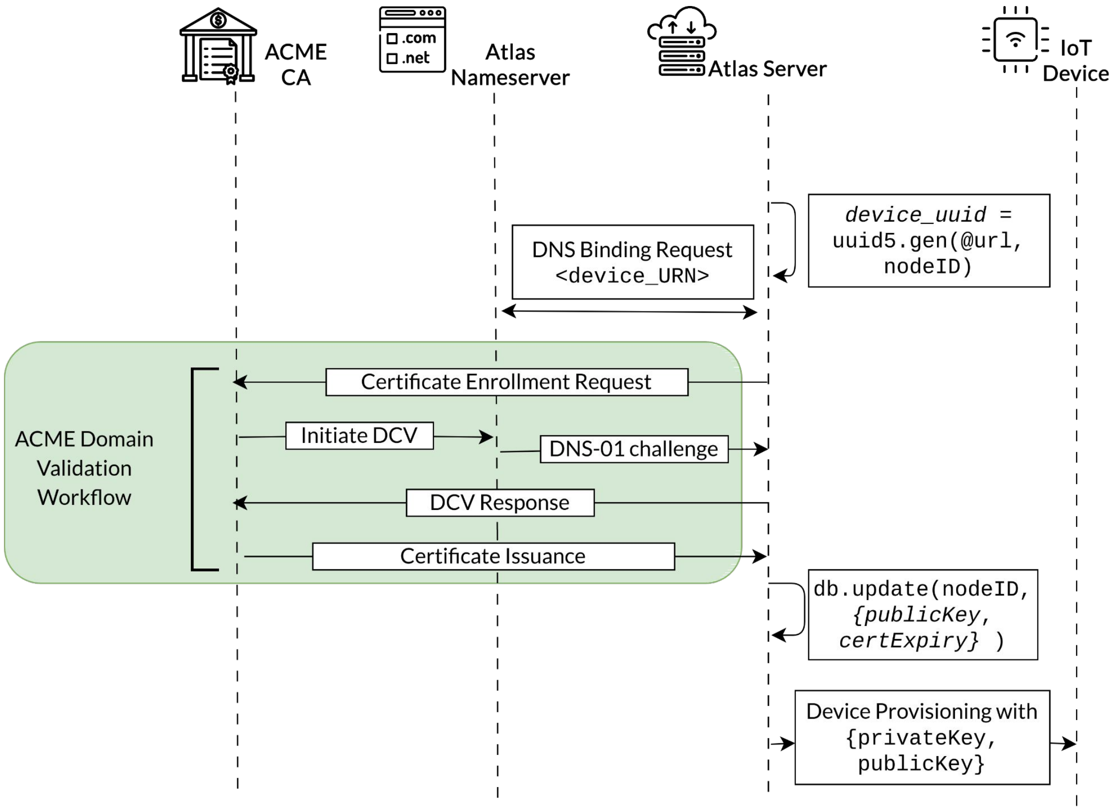
Atlas: Extending ACME with IoT Namespaces

TABLE 2: An example Namespace for IoT devices. *Note that, ATLAS's design is parametric to the choice of namespace* and can support other vendor-specific customization.

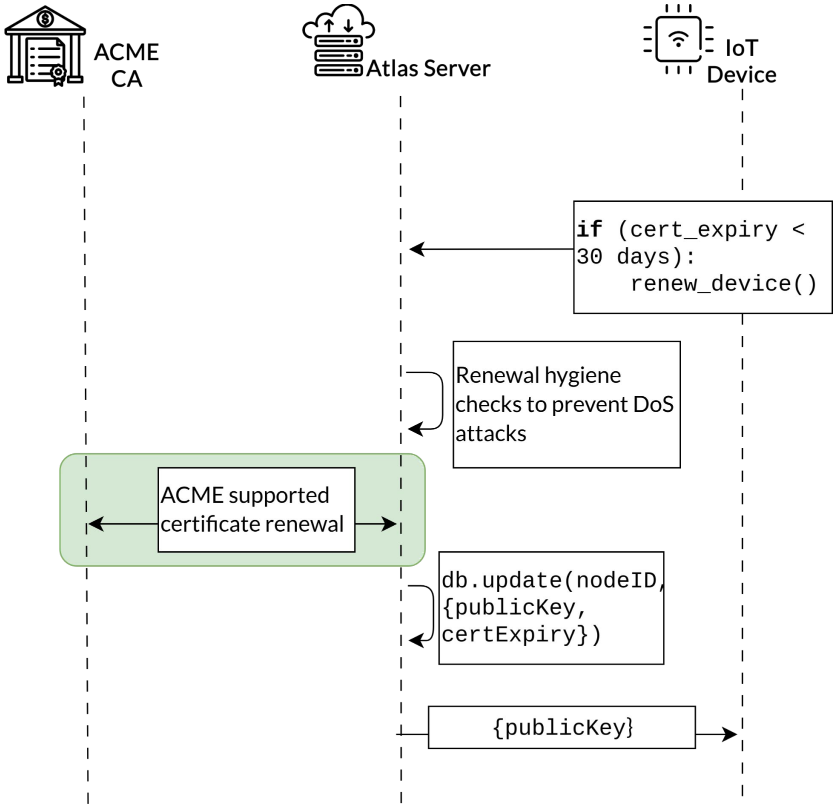
⟨URN⟩	⊨	⟨UUID⟩.⟨device-class⟩.⟨root-domain⟩
⟨UUID⟩	⊨	4⟨hexOctet⟩-2⟨hexOctet⟩-2⟨hexOctet⟩-2⟨hexOctet⟩-6⟨hexOctet⟩
⟨hexOctet⟩	⊨	⟨hexDigit⟩⟨hexDigit⟩
⟨hexDigit⟩	⊨	⟨digit⟩ | A | B | C | D | E | F
⟨digit⟩	⊨	%x30-39
⟨device-class⟩	⊨	*Vendor-specific categorization of the device,* e.g., *'smart-speaker', 'smart-hub', etc.*
⟨root-domain⟩	⊨	*The root domain of the vendor,* e.g., *'amazon.com', 'ring.com', etc.*



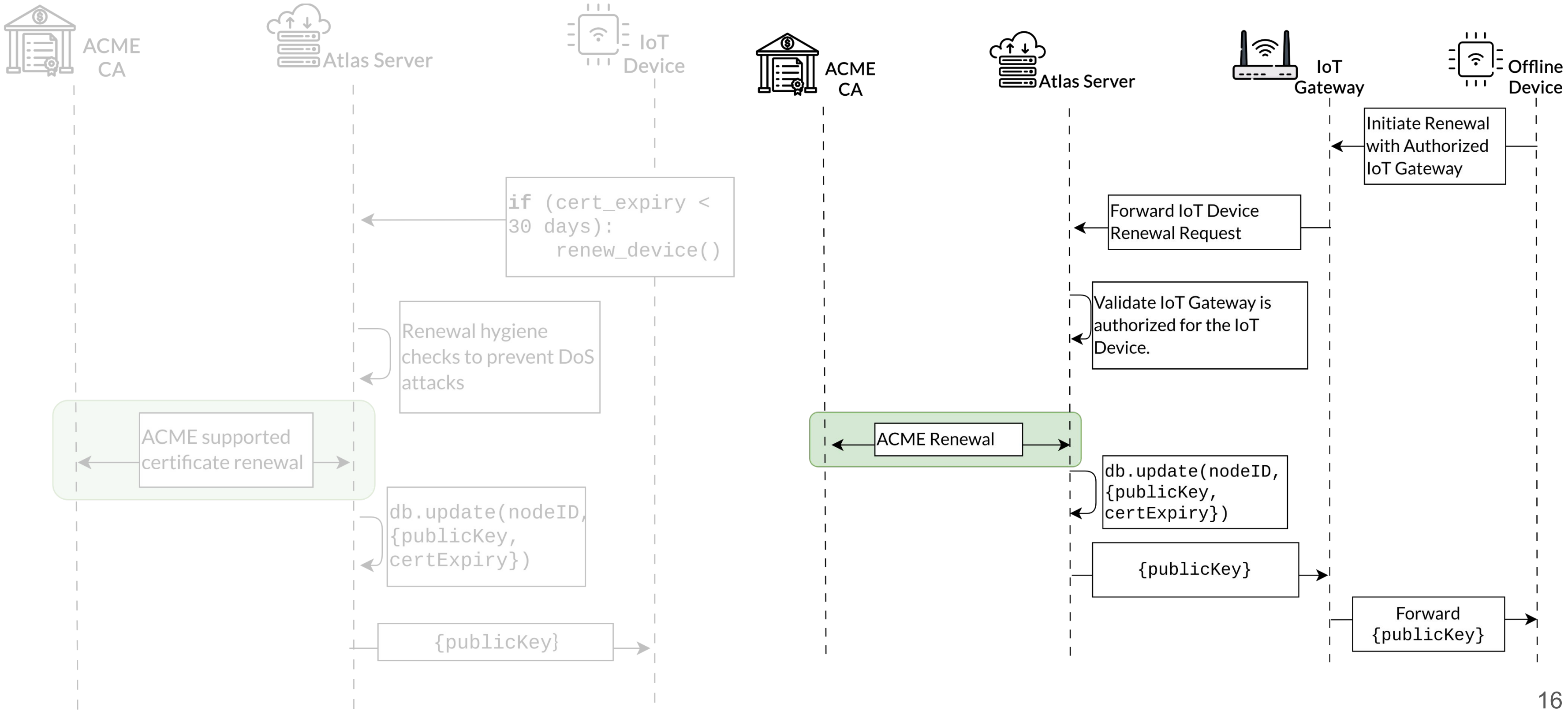
Atlas: Binding and Enrollment step



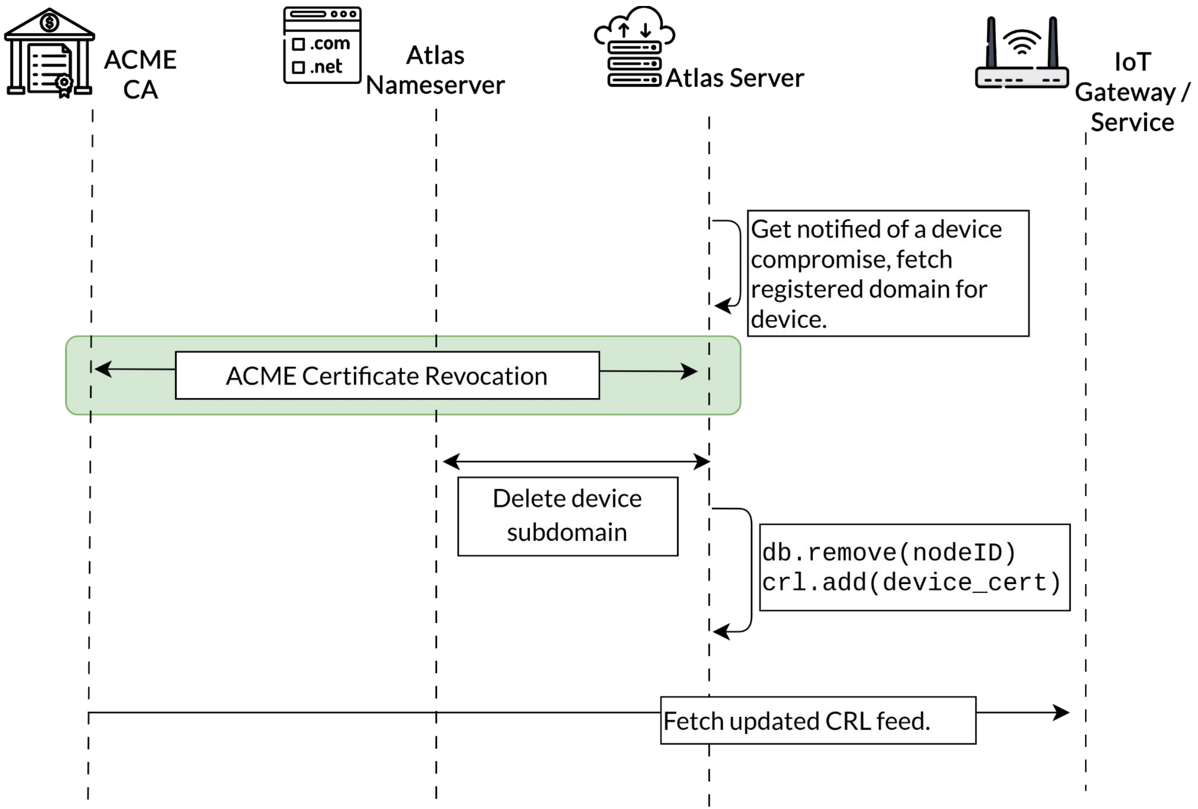
Atlas: Automatic Renewal of Online IoT Device



Atlas: Automatic Renewal of Offline IoT Device

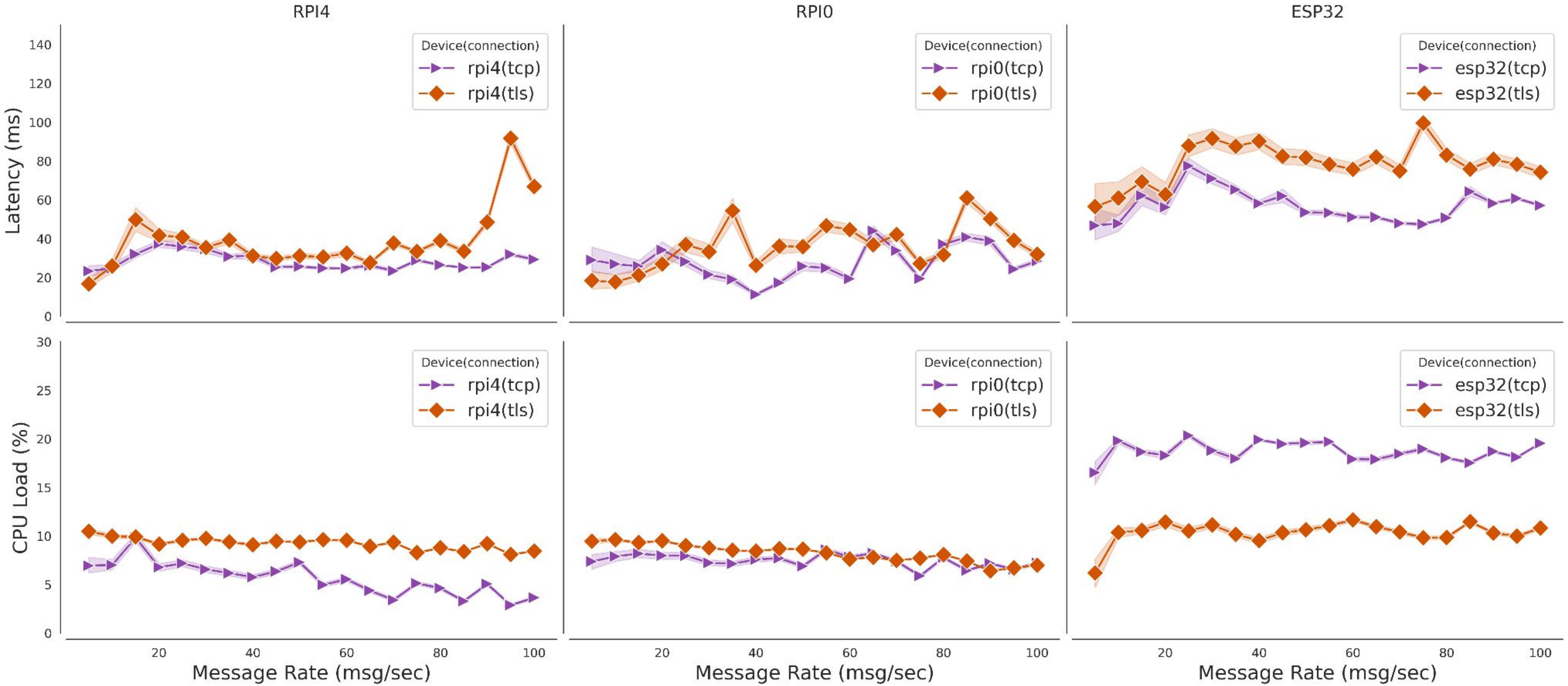


Atlas: Fine-grained Revocation of Compromised Devices



Atlas: Enforces mutual-TLS for Cross-Vendor Interaction

Is mutual-TLS practical in IoT?



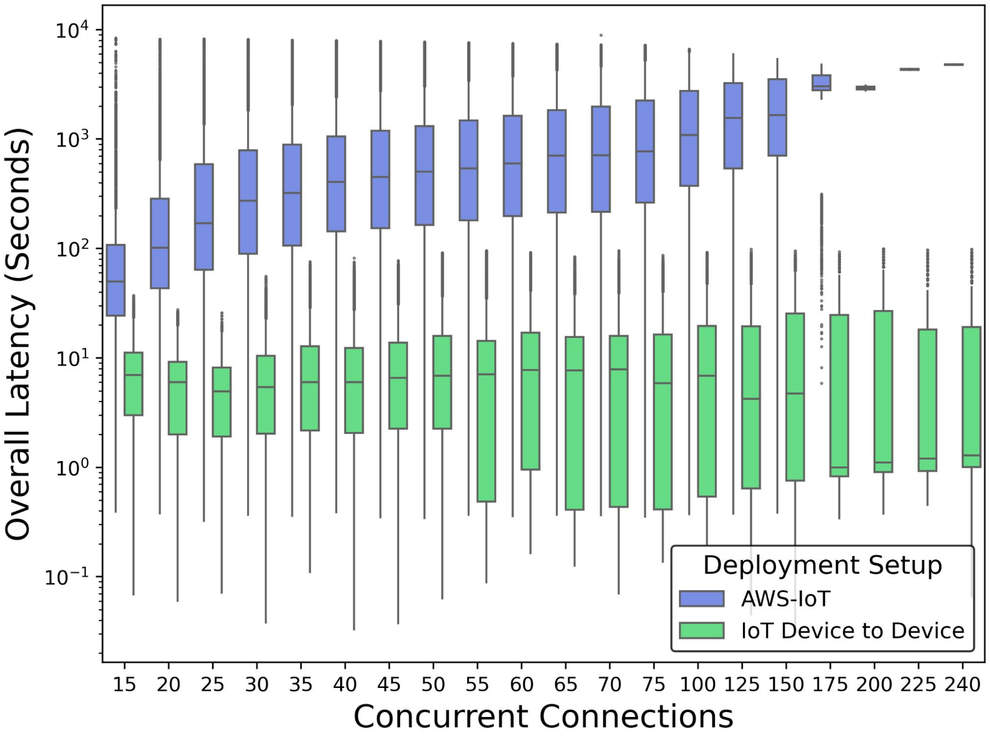
Modern microcontrollers are highly performant for TLS.

TABLE 3: Latency measurements show that the overhead of TLS is well within the real-time performance thresholds for IoT. Modern micro-controllers (*e.g.*, esp32) have dedicated cryptographic accelerators that offload all TLS computation, which is why our load measurement on general purpose CPU for TLS in lower than TCP.

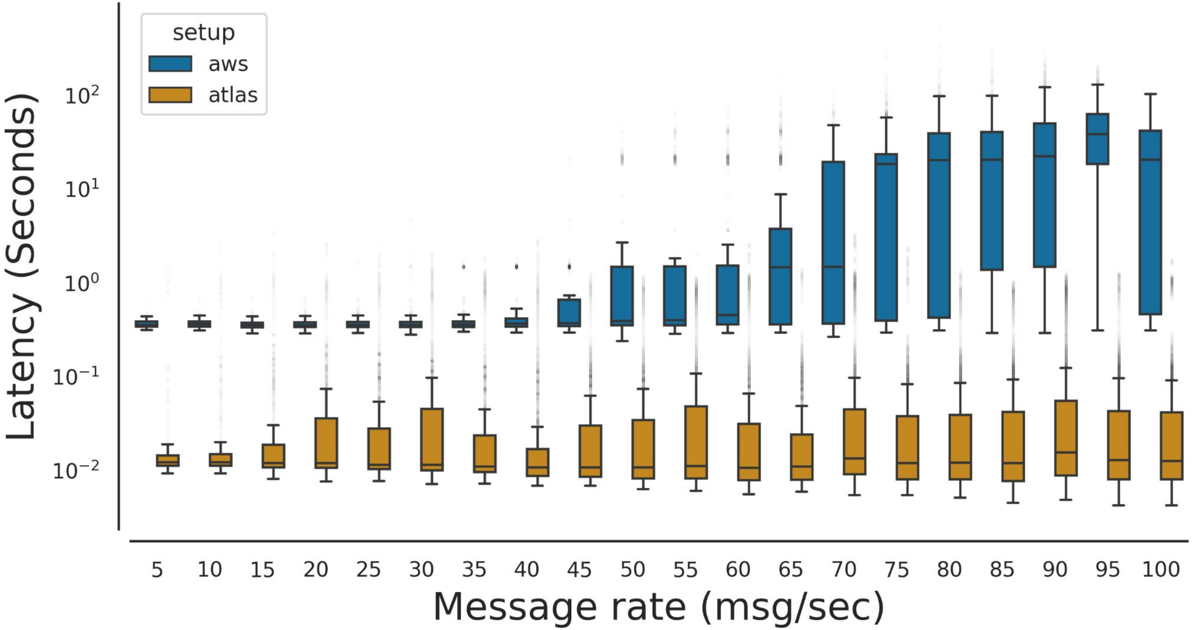
Metric		**rpi4**	**rpi0**	**esp32**
Latency (ms)	tcp	27.678543	29.253048	56.541336
	tls	44.278107	39.473658	80.758832
CPU Usage (%)	tcp	4.802685	7.282358	18.690758
	tls	8.943186	7.691518	10.557885

Comparison against cloud-first setups.

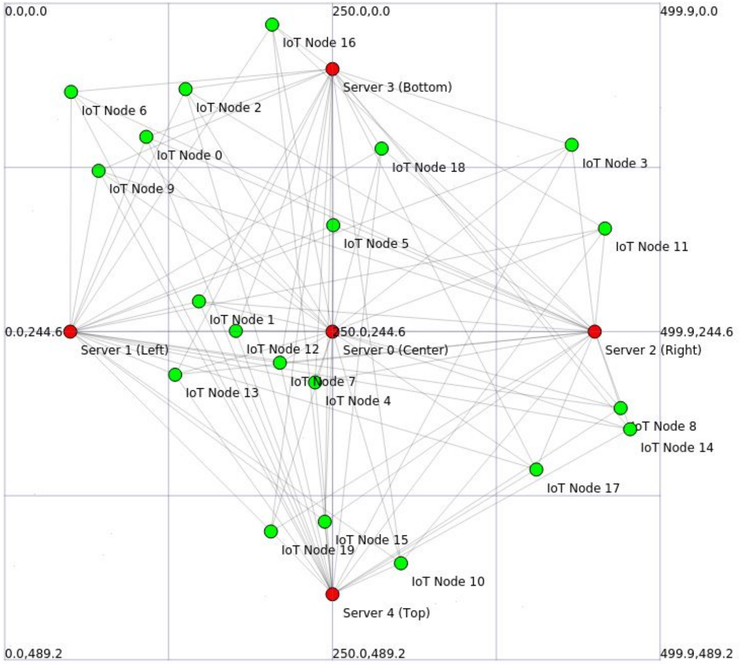
IoT Clouds (AWS-IoT) start rate limiting applications under stress (>100 connections), resulting in lower throughput due to packet loss, despite claiming to support higher limits (250 connections).

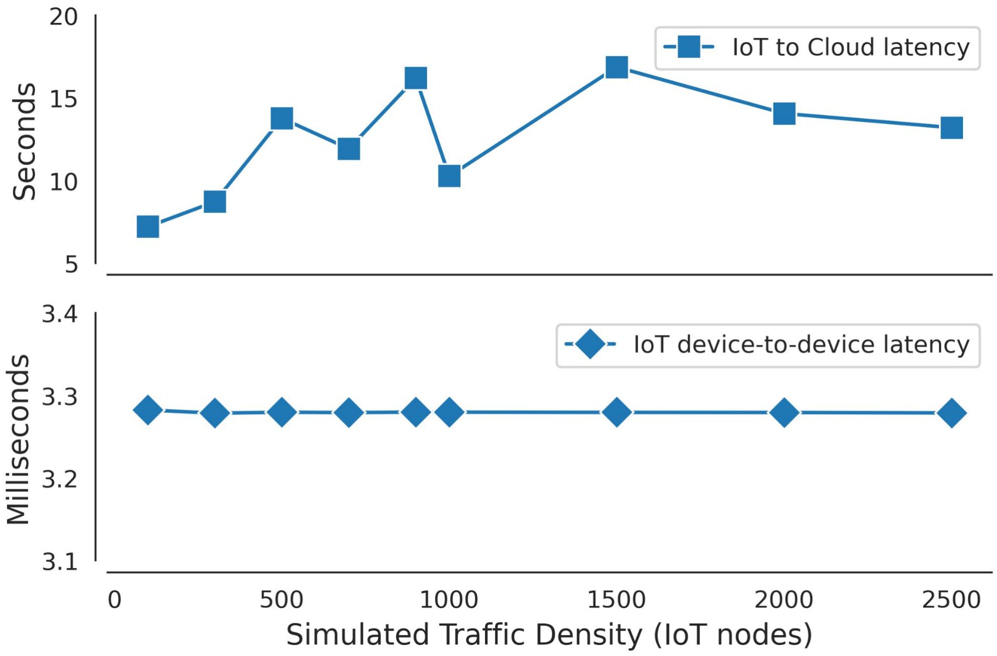


IoT Applications using **Atlas** – Smart Home Automation



IoT Applications using **Atlas** – Smart City Simulation





Mobile IoT Nodes (vehicles) interacting with Static IoT Gateways (traffic lights)

Atlas: Cross-Vendor IoT Device-to-Device Authentication

- Heterogeneity in IoT devices and their supported platforms has led to a fragmented ecosystem.
- We studied existing authentication systems, and identified key trends that inhibit interoperability and scalability between vendors and service providers.
- We developed Atlas to adapt the ACME model of Web PKI for the IoT ecosystem.
- Atlas enables secure and direct device-to-device communication pathways, demonstrating performant and scalable IoT applications.